

Internship Task Report: Task 6 Day 6

Date: [9.06.2026]

Intern Name: [Mahek.oza]

(Interns Batch):- Cyber security

Target Website: [<https://kryosync.netlify.app>]

Task:- security Assessment on a test environment:-

1. Reconnaissance

Infrastructure

Item

Observation

Domain

<https://kryosync.netlify.app>

Hosting

Netlify

SSL/TLS

HTTPS enabled

Application Type

Static marketing/business website

Mobile Support

Present

Public Contact Information

Exposed on website

Technology indicators include:

Netlify hosting

HTML5

CSS

Google Fonts

Responsive/mobile design

UTF-8 encoding

BuiltWith +1

Information Disclosure Findings

The website publicly exposes:

Company email addresses

HR email address

Mobile phone number

Founder and leadership names

Physical location (Bhavnagar, Gujarat)

Examples observed:

kryosyncc@gmail.com

hrrkryosyncc@gmail.com

+91 84608 54038

These are legitimate business disclosures but increase exposure to:

Phishing campaigns

Spam

Social engineering attacks

Credential harvesting attempts

Risk: Medium

2. Application Security Review

Attack Surface Analysis

Public Pages

Observed sections:

Home

Services

Portfolio

Testimonials

About

Leadership

Workshops

Contact Information

No obvious login portal, admin panel, or customer dashboard was observed in publicly indexed content.

Forms

Potential areas requiring validation:

Contact forms

Lead-generation forms

Inquiry submissions

Security controls that should be verified:

Input sanitization

CAPTCHA protection

Rate limiting

Email validation

Potential Risk: Medium

Client-Side Security

Because Netlify sites often rely heavily on frontend JavaScript:

Potential concerns include:

Exposed API Keys

Review JavaScript bundles for:

Firebase keys

AWS credentials

Email service tokens

Analytics secrets

Risk if present: High

Third-Party Dependencies

The site uses external resources such as Google Fonts. Third-party dependencies increase:

Supply-chain risk

Dependency compromise risk

Tracking/privacy exposure

Risk: Low-Medium

3. Security Header Assessment

A full header scan was not performed, so findings below represent items that should be verified.

Critical Headers

Content Security Policy (CSP)

Protects against:

Cross-Site Scripting (XSS)

Malicious script injection

Recommended:

Http

Content-Security-Policy:

Default-src 'self';

Script-src 'self';

Style-src 'self' <https://fonts.googleapis.com>

Font-src <https://fonts.gstatic.com>;

Risk if absent: High

Strict-Transport-Security (HSTS)

Forces HTTPS communication.

Recommended:

Http

Strict-Transport-Security:

Max-age=31536000;

includeSubDomains;

preload

Risk if absent: Medium

X-Frame-Options

Protects against clickjacking.

Recommended:

Http

X-Frame-Options: SAMEORIGIN

Risk if absent: Medium

X-Content-Type-Options

Prevents MIME-type confusion attacks.

Recommended:

Http

X-Content-Type-Options: nosniff

Risk if absent: Medium

Referrer-Policy

Reduces information leakage.

Recommended:

Http

Referrer-Policy: strict-origin-when-cross-origin

Risk if absent: Low-Medium

Security-header best practices are widely recommended because they mitigate XSS, clickjacking, MIME-sniffing, and transport-security weaknesses. [?](#)

Develop.tools +2

4. OWASP Top 10 Exposure Review

Category

Likelihood

Broken Access Control

Low

Cryptographic Failures

Low

Injection Attacks

Low (static site)

Insecure Design

Medium

Security Misconfiguration

Medium

Vulnerable Components

Medium

Identification & Authentication Failures

Low

Software Integrity Failures

Medium

Logging & Monitoring Failures

Unknown

SSRF

Very Low

5. Risk Classification

Finding

Severity

Public Contact Information Exposure

Medium

Social Engineering Risk

Medium

Potential Missing CSP

High

Potential Missing HSTS

Medium

Potential Missing X-Frame-Options

Medium

Third-Party Dependency Risk

Medium

Exposed Frontend Secrets (if any)

High

Netlify Configuration Issues

Medium

Lack of Rate Limiting on Forms

Medium

6. Mitigation Recommendations

Immediate (High Priority)

Implement Security Headers

Configure in netlify.toml:

TOML

[[headers]]

For = “/*”

[headers.values]

X-Frame-Options = “SAMEORIGIN”

X-Content-Type-Options = “nosniff”

Referrer-Policy = “strict-origin-when-cross-origin”

Strict-Transport-Security = “max-age=31536000; includeSubDomains; preload”

Audit Frontend Code

Review:

JavaScript bundles

Environment variables

API integrations

Public repositories

Remove:

Hardcoded credentials

Access tokens

Private endpoints

Protect Contact Forms

Add:

CAPTCHA

Rate limiting

Email verification

Input validation

Medium Priority

Dependency Management

Implement:

Npm audit

Dependabot

Automated vulnerability scanning

Content Security Policy

Deploy strict CSP rules to reduce XSS exposure.

Long-Term

Quarterly security assessments

Dependency review process

Secret-scanning in CI/CD

Continuous monitoring

Security awareness training for staff